

---

## Sécurité et administration

---

**CER | S.I.**

---

Mardi 18 novembre 2025

# TABLE DES MATIÈRES

---

# ÉTUDE DE CAS: LA RANÇON DU CYBERESPACE

---

## AAV

---

- 5 Renforcer la vision globale du Système d'Information
- 3 Inventorier les différents composants du Système d'Information
- 4 Etablir une cartographie du Système d'Information
- 4 Analyser de manière holistique la sécurité du S.I.
- 1 Rappeler le cadre légal
- 3 Préparer des scripts sous Linux
- 5 Réorganiser la sécurité d'une infrastructure

## MOTS CLÉS

---

- Ransomware
- Système d'information
- ANSSI
- MOOC
- ERP
- CTO
- DSI
- CNIL
- Vecteur d'attaque
- Cybermenaces
- Durcissement
- Anti Virus
- Privilèges
- RSSI
- Infection par PDF
- RGPD

## CONTEXTE

---

Léo arrive dans un climat tendu suite à une attaque par ransomware sur une entreprise voisine. Sa responsable saisie cette opportunité pour renforcer la sécurité et sensibiliser le personnel de BERRIA.

## PROBLÉMATIQUE

---

Comment sécuriser le système d'information de BERRIA contre les ransomwares et autres cybermenaces, tout en sensibilisant efficacement le personnel aux bonnes pratiques de sécurité informatique?

## CONTRAINTES

---

- Windows
- ANSSI
- MOOC
- Wifi Invité
- Cadre légale

## GÉNÉRALISATION

---

- Cybersécurité
- Sensibilisation
- Administration Système
- Législation (RGPD)

## LIVRABLES

---

- Plaque de prévention
- Script de Sécurisation W10
- Rapport d'étude

## PISTES DE SOLUTIONS

---

- MOOC SecNum Académie
- Guide ANSSI
- Principe de moindre privilège
- Kiosk Mode
- Analyse des vecteurs d'attaque
- Sauvegarde déconnectée

## PLAN D'ACTION

---

- Définir les mots clés
- Etudier les ressources
- Etudier les différentes cybermenaces et vecteurs d'attaques
- Comprendre la différence entre SI et SI informatique
- Suivre MOOC de l'ANSSI
- Recenser les règles de la CNIL
- Rechercher les méthodes de durcissement Windows 10
- Mettre en place une maquette pour tester la configuration
- Rédiger la plaquette de sensibilisation
- Rédiger le rapport final

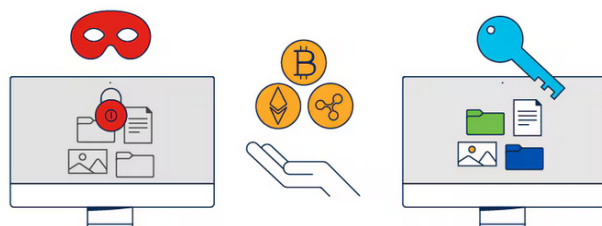
# DÉMARCHE : LA RANÇON DU CYBERESPACE

---

## DÉFINITION: MOTS CLÉS

---

**Ransomware:** Un ransomware est un logiciel malveillant qui chiffre ou exfiltre des données et peut bloquer l'accès aux systèmes jusqu'au paiement d'une rançon.



Les vecteurs d'infection les plus courants sont :

- le phishing (pièces jointes ou liens malveillants) ;
- les services exposés non protégés (RDP, SMB) ;
- les vulnérabilités non corrigées ;
- la compromission de comptes à privilèges.

Mesures essentielles de prévention et réponse :

- sauvegardes régulières, testées et idéalement isolées (*air-gapped*) ;
- segmentation réseau ;
- authentification multi-facteur (MFA) ;
- gestion stricte des privilèges ;
- détection comportementale (EDR) ;
- plan de réponse à incident incluant préservation des preuves et notification des autorités (ANSSI / CERT-FR).

Le paiement d'une rançon est déconseillé : aucune garantie de récupération et encourage la criminalité. Il est recommandé d'impliquer les forces de l'ordre et les CERT nationaux.

**Système d'information (SI):** Un SI regroupe l'ensemble des ressources techniques, humaines et organisationnelles permettant de collecter, traiter, stocker et diffuser l'information. Un SI maîtrisé repose sur :

- une cartographie des actifs (postes, serveurs, applications, données) ;
- une gestion rigoureuse des identités et des accès (IAM) ;
- un pilotage clair (rôles, responsabilités, procédures) ;
- des sauvegardes fiables et testées ;
- une supervision continue et une gestion d'incidents structurée ;
- un inventaire centralisé (CMDB).

**ANSSI :** L'Agence Nationale de la Sécurité des Systèmes d'Information est l'autorité française en cybersécurité.

Ses rôles principaux :

- publication de guides et bonnes pratiques ;
- coordination d'incidents majeurs via le CERT-FR ;
- qualification d'acteurs et solutions ;
- sensibilisation et accompagnement.



**MOOC:** Formations en ligne ouvertes permettant de monter en compétences en sécurité. Privilégier les MOOC de l'ANSSI, d'universités ou de fournisseurs reconnus, avec exercices pratiques.

**ERP:** Un ERP centralise des processus métiers critiques (RH, finances, achats, production). Mesures de sécurité essentielles :

- contrôle strict des accès (IAM, MFA) ;
- gestion des correctifs ;
- segmentation réseau ;
- chiffrement des données ;
- sauvegardes applicatives cohérentes.

**CTO:** Le Chief Technology Officer définit la stratégie technologique. Rôles liés à la sécurité :

- intégrer le *security by design* dans l'architecture ;
- arbitrer les investissements (EDR, SIEM, backups) ;
- aligner vision technologique et contraintes de risque.

**DSI:** Le Directeur des Systèmes d'Information gère l'exploitation du SI. Responsabilités clés :

- mise en œuvre de la politique de sécurité ;
- mises à jour, sauvegardes, supervision ;
- gestion des incidents ;
- conformité réglementaire (RGPD).

**CNIL :** La Commission Nationale de l'Informatique et des Libertés (CNIL) est l'autorité française chargée de veiller au respect de la protection des données personnelles (RGPD). En cas d'incident de sécurité impliquant des données personnelles, obligations et bonnes pratiques :

- documenter immédiatement l'incident (nature, périmètre, causes, données concernées) ;
- évaluer l'impact et le risque pour les personnes concernées (DPIA si nécessaire) ;
- notifier la CNIL dans les 72 heures lorsqu'un risque pour les droits et libertés est probable ;
- informer les personnes concernées si le risque est élevé, en précisant les mesures d'atténuation recommandées ;
- consigner l'incident et les actions correctives dans le registre des violations ;
- coopérer avec la CNIL et le Délégué à la Protection des Données (DPO) durant l'enquête ;
- mettre en place des mesures préventives : minimisation des données, chiffrement, contrôle d'accès, sauvegardes isolées, journalisation et sensibilisation du personnel.

Sanctions possibles : mesures correctrices et amendes administratives prévues par le RGPD en cas de manquement grave.

**RGPD :** Le Règlement Général sur la Protection des Données (RGPD) encadre le traitement des données à caractère personnel au sein de l'Union européenne. Il garantit la protection des droits et libertés des personnes physiques et impose des obligations aux organisations qui collectent, traitent ou conservent ces données.

Principes clés :

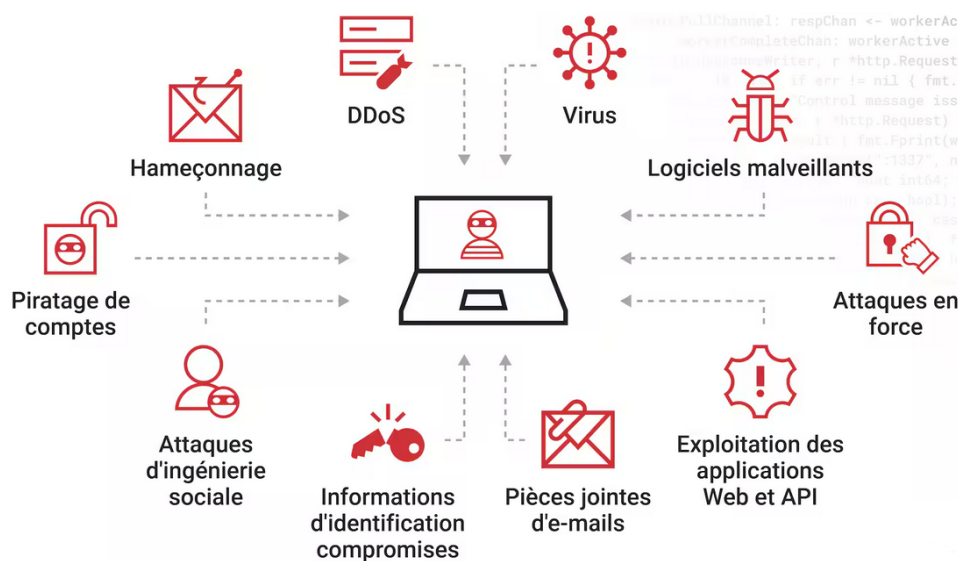
- licéité, loyauté et transparence ;
- limitation des finalités ;
- minimisation des données ;
- exactitude et conservation limitée ;
- intégrité et confidentialité (sécurité des traitements).

Obligations principales :

- disposer d'une base légale pour chaque traitement (consentement, exécution de contrat, obligation légale, intérêt légitime, etc.) ;
- respecter et faciliter l'exercice des droits des personnes (accès, rectification, effacement, limitation, portabilité, opposition) ;
- mettre en place des mesures techniques et organisationnelles adaptées (pseudonymisation, chiffrement, contrôle d'accès, journalisation) ;
- documenter les traitements et tenir un registre des activités lorsque requis ;
- notifier les violations de données à l'autorité de contrôle compétente dans les 72 heures et informer les personnes concernées si le risque est élevé ;
- désigner un délégué à la protection des données (DPO) lorsque nécessaire et encadrer les transferts hors UE.

Sanctions : la non-conformité peut entraîner des mesures correctrices et des amendes administratives importantes (jusqu'à 20 millions d'euros ou 4% du chiffre d'affaires mondial annuel).

**Vecteurs d'attaque:** Méthodes utilisées par un attaquant pour compromettre un système :



- phishing / spear-phishing ;
- pièces jointes malveillantes ;
- vulnérabilités non corrigées ;
- services exposés sans durcissement ;
- compromission de la chaîne d'approvisionnement ;
- abus de comptes tiers.

**Cybermenaces:** Regroupe malwares, ransomware, DDoS, espionnage, vol d'identifiants, menaces internes. Une stratégie efficace repose sur :

- threat modelling ;
- indicateurs de compromission (IOC) ;
- threat intelligence ;
- corrélation d'événements via SIEM.

**Durcissement:** Réduction de la surface d'attaque :

- suppression des services inutiles ;
- application des correctifs ;
- moindre privilège ;
- MFA, politiques robustes ;
- protections natives (pare-feu, AppLocker, ASR) ;
- configuration as code.

**Antivirus:** Un antivirus (AV) détecte et bloque principalement les menaces connues via des signatures et des heuristiques, mais il ne suffit pas à lui seul face aux attaques ciblées et aux menaces sans signature.

Pour une protection robuste, on recommande de :

- coupler l'AV avec une solution EDR pour la détection comportementale, l'investigation et la réponse automatisée ;
- maintenir à jour les signatures, le moteur et le système d'exploitation, et activer les protections cloud/heuristiques ;
- centraliser les alertes et corréler les événements dans un SIEM pour détecter les campagnes et les mouvements latéraux ;
- définir des politiques d'exclusion maîtrisées et des procédures d'isolement pour limiter l'impact des faux positifs ;
- compléter par segmentation réseau, sauvegardes isolées, MFA, contrôles d'accès stricts et sensibilisation des utilisateurs.

**Privilèges:** Gestion conforme au principe du moindre privilège :

- séparation comptes admin / utilisateurs ;
- élévation temporaire (*just-in-time*) ;
- revue régulière des droits ;
- MFA obligatoire ;
- journalisation renforcée.

**RSSI:** Le Responsable de la Sécurité des Systèmes d'Information pilote la stratégie de sécurité. Rôles clés :

- évaluation des risques ;
- définition de la politique de sécurité ;
- sensibilisation et formation ;
- gestion des incidents ;
- conformité réglementaire.
- supervision des outils de sécurité.

**Infections via PDF:** Les PDF peuvent embarquer scripts ou objets malveillants. Mesures :

- désactivation de JavaScript dans les lecteurs ;
- mises à jour régulières ;
- filtrage et sandbox des pièces jointes ;
- conversion en texte pour analyse ;
- sensibilisation des utilisateurs.

# CORBEILLE D'EXERCICE

## INTRODUCTION À LA SÉCURISATION DU POSTE DE TRAVAIL ET À POWERSHELL

**Introduction:** PowerShell se présente sous deux formes :

- La console PowerShell (PS) qui interprète les commandes en ligne (Figure à gauche),
- Un environnement graphique de développement de scripts – PowerShell Integrated Scripting Environment (PS-ISE) (figure à droite).

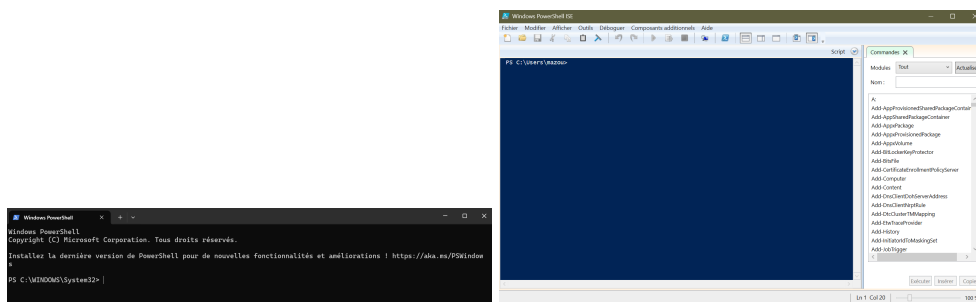
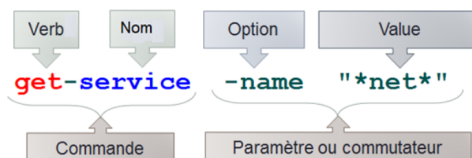


Figure 1: Console PowerShell et PowerShell ISE

Pour lancer PS, aller dans le menu **Démarrer > Tous les Programmes > Accessoires > Windows PowerShell** et choisissez l'interface souhaitée, Il est également possible de lancer PS avec l'interpréteur classique de commandes de Windows (cmd.exe) avec la commande **PowerShell**.

Les "cmdlet" sont composées d'une paire de la forme "verbe" -"nom" destinées à en faciliter la mémorisation.



**Exemples de cmdlet :**

- Get-Process : Affiche la liste des processus en cours d'exécution.
- Get-Service : Affiche la liste des services installés sur le système.
- Get-EventLog : Affiche les journaux d'événements du système.
- Set-ExecutionPolicy : Modifie la politique d'exécution des scripts PowerShell.

PowerShell propose 4 modes d'exécution des scripts :

- **Restricted** : Mode par défaut, n'autorise pas l'exécution de scripts.
- **AllSigned** : N'autorise l'exécution que des scripts signés par un éditeur de confiance.
- **RemoteSigned** : Autorise l'exécution des scripts locaux non signés, mais exige que les scripts téléchargés soient signés.
- **Unrestricted** : Autorise l'exécution de tous les scripts, mais affiche un avertissement pour les scripts téléchargés.

En tant que script PowerShell permet de déclarer une variable.

- **Nom / Identifiant** : Étiquette permettant de référencer la variable dans le code.
- **Type** : Définit le format des données (entier, flottant, chaîne, objet) et les opérations possibles.
- **Valeur** : Contenu actuel stocké dans la variable.
- **Portée (scope)** : Zone du programme où la variable est accessible (locale, globale, de bloc, de fonction).
- **Durée de vie (lifetime)** : Période pendant laquelle la variable existe en mémoire (statique, automatique, dynamique).
- **Mutabilité / Constante** : Indique si la valeur peut être modifiée après initialisation.
- **Allocation mémoire / Taille** : Emplacement et taille en mémoire (pile, tas, adresse) et contraintes associées.

### Exemple de script opérationnels :

1. Inviter l'utilisateur à saisir son prénom et son âge, et afficher une phrase récapitulative « Bonjour XXX vous avez Y ans. »

```
$prenom = Read-Host "Entrez votre prénom"
$age = Read-Host "Entrez votre âge"
Write-Host "Bonjour $prenom, vous avez $age ans."
```

2. Voici un jeu. Vous devez inviter l'utilisateur à deviner un nombre :

- Tirer un nombre aléatoire entier entre 0 et 100
- Inviter l'utilisateur à entrer son essai
  - Si l'utilisateur est plus haut, afficher en rouge « Trop haut ! mon nombre est plus bas. »
  - Si l'utilisateur est plus bas, afficher en gris « Trop bas ! mon nombre est supérieur. »
  - Si l'utilisateur devine le nombre, afficher en vert « bravo, vous avez trouvé en XXX essais ! » (et compter le nb d'essais)

```

$nombreSecret = Get-Random -Minimum 0 -Maximum 100
$essais = 0
do {
    $essais++
    $essai = Read-Host "Devinez le nombre (entre 0 et 100)"
    if ($essai -lt $nombreSecret) {
        Write-Host "Trop bas ! mon nombre est supérieur."
        -ForegroundColor Gray
    }
    elseif ($essai -gt $nombreSecret) {
        Write-Host "Trop haut ! mon nombre est plus bas."
        -ForegroundColor Red
    }
} while ($essai -ne $nombreSecret)
Write-Host "Bravo, vous avez trouvé en $essais essais !"
-ForegroundColor Green

```

3. Comment lancer Notepad (ou un autre programme...) s'il n'est pas déjà lancé en mémoire ?

```

$processName = "notepad"
$process = Get-Process -Name $processName -ErrorAction SilentlyContinue
if ($null -eq $process) {
    Start-Process $processName
    Write-Host "$processName a été lancé."
} else {
    Write-Host "$processName est déjà en cours d'exécution."
}

```

## GÉRER LES UTILISATEUR LOCAUX SUR UN POSTE AVEC UN SYSTÈME WINDOWS

Lorsqu'ils sont mal utilisés, les privilèges d'administrateur local d'un PC Windows peuvent causer de graves dommages à l'ordinateur de l'utilisateur, exposer d'autres ordinateurs sur un réseau donné et rendre les machines plus vulnérables aux virus et aux acteurs malveillants, ce qui crée encore plus de défis et de problèmes pour le service informatique de l'organisation.

Windows permet d'ajouter plusieurs comptes d'utilisateur pour utiliser le même appareil, ce qui permet à chaque utilisateur d'avoir ses propres paramètres, documents et applications.

Les comptes d'utilisateur locaux sont définis localement sur un appareil et peuvent se voir attribuer des droits et des autorisations uniquement sur l'appareil. Les comptes d'utilisateur locaux sont utilisés pour sécuriser et gérer l'accès aux ressources sur un appareil, pour les services ou les utilisateurs.

- **Les comptes d'utilisateur locaux par défaut** sont des comptes intégrés qui sont créés automatiquement lorsque le système d'exploitation est installé. Les comptes d'utilisateur locaux par défaut ne peuvent pas être supprimés ou supprimés et ne fournissent pas l'accès aux ressources réseau.
- **Le compte d'administrateur local par défaut** est un compte d'utilisateur pour l'administration du système. Le compte Administrateur est le premier compte créé pendant l'installation de Windows. Le compte administrateur par défaut ne peut pas être supprimé ou verrouillé, mais il peut être renommé ou désactivé.
- **Le compte Invité** permet aux utilisateurs occasionnels ou ponctuels, qui n'ont pas de compte sur l'ordinateur, de se connecter temporairement au serveur local ou à l'ordinateur client avec des droits d'utilisateur limités. Par défaut, le compte Invité est désactivé et a un mot de passe vide02

#### Exemple de script pour gérer les utilisateurs locaux :

##### 4. Comment créer un compte utilisateur local dans Windows 10 ou 11 ?

```
$username = "NouvelUtilisateur"
$password = "MotDePasseSecurise123!" |
    ConvertTo-SecureString -AsPlainText -Force
New-LocalUser -Name $username
    -Password $password
    -FullName "Utilisateur Local"
    -Description "Compte utilisateur local créé via PowerShell"
Add-LocalGroupMember -Group "Users" -Member $username
Write-Host "Le compte utilisateur local '$username' a été créé
avec succès."
```

##### 5. Comment accéder à la base de compte locale sur un PC Windows 10 ou 11 avec un outil graphique? (sauf pour l'édition Famille)

lusrmgr.msc

##### 6. Où se trouve la base des comptes locaux dans le système de fichier d'un poste Windows ?

C:\Windows\System32\config\SAM

## 7. Comment utiliser PowerShell pour réaliser les actions suivantes ?

- Listez les comptes utilisateurs locaux de la machine.
- Créez un nouveau compte non administrateur.
- Créez un nouveau compte administrateur.

Attention, dans les 2 cas il faut demander de taper le login souhaité, le mot de passe et re-taper le mot de passe pour vérification

```
# Lister les comptes utilisateurs locaux
Get-LocalUser

# Créer un nouveau compte non administrateur
$username = Read-Host "Entrez le nom d'utilisateur"
$password = Read-Host "Entrez le mot de passe" -AsSecureString
New-LocalUser -Name $username
    -Password $password
    -FullName "Utilisateur Local"
    -Description "Compte utilisateur local non administrateur"
Add-LocalGroupMember -Group "Users" -Member $username
Write-Host "Le compte utilisateur local '$username' a été créé
avec succès."

# Créer un nouveau compte administrateur
$adminUsername = Read-Host "Entrez le nom d'utilisateur
administrateur"
$adminPassword = Read-Host "Entrez le mot de passe
administrateur" -AsSecureString
New-LocalUser -Name $adminUsername
    -Password $adminPassword
    -FullName "Administrateur Local"
    -Description "Compte administrateur local"
Add-LocalGroupMember -Group "Administrators" -Member $adminUsername
Write-Host "Le compte administrateur local '$adminUsername' a
été créé avec succès."
```

## LA SÉCURITÉ DES POSTES WINDOWS AVEC WINDOWS SECURITY

L'application de sécurité Windows (Windows Security) existe sur les postes Windows et les serveurs Windows. L'interface graphique est disponible sur Windows 10 et 11. Les fonctions peuvent être gérées en PowerShell.

| Fonctionnalité                         | Windows 10 Éducation                           | Windows Server 2022 Standard                   |
|----------------------------------------|------------------------------------------------|------------------------------------------------|
| Application "Sécurité Windows" (GUI)   | Complète et activée par défaut                 | Présente mais souvent désactivée ou minimale   |
| Microsoft Defender Antivirus           | Activé et fonctionnel par défaut               | Inclus, mais peut être désactivé               |
| Protection en temps réel               | Activée                                        | Désactivée par défaut                          |
| Protection basée sur le cloud          | Activée                                        | Désactivée par défaut, à activer               |
| Mises à jour de signatures Defender    | Automatiques via Windows Update                | Automatiques si Defender est actif             |
| Protection contre les ransomwares      | Disponible avec "Accès contrôlé aux dossiers"  | Fonction disponible mais désactivée par défaut |
| Pare-feu Windows Defender              | Activé, configurable via GUI                   | Activé par défaut                              |
| Sécurité matérielle (TPM, Secure Boot) | Compatible, dépend du matériel                 | Compatible, dépend du serveur                  |
| Notifications de sécurité              | Activées                                       | Désactivées dans de nombreux cas (serveur)     |
| Gestion via GPO                        | Oui, pour toutes les fonctionnalités           | Oui, fortement recommandée                     |
| Gestion via PowerShell (Get-Mp*)       | Oui                                            | Oui                                            |
| Microsoft Defender SmartScreen         | Activé                                         | Non présent ou inactif sur les serveurs        |
| Contrôle des applications (AppLocker)  | Oui (via GPO)                                  | Oui (via GPO, souvent utilisé)                 |
| Mode multi-utilisateurs / domaine      | Compatible avec AD, mais usages "poste client" | Conçu pour les domaines et serveurs            |

Table 1: Tableau récapitulatif des mesures de sécurisation

## PROTECTION ANTIVIRUS

---

Pour tester le fonctionnement d'un antivirus nous utiliser le fichier de test Eicar, qui est une chaîne de caractères, écrite dans un fichier informatique.

Créez un fichier texte (utilisez le Bloc-notes de Windows par exemple) avec le contenu suivant que vous pouvez copier et coller dans votre fichier :

```
X50!P%@AP[4\PZX54(P^)7CC)7}$EICAR-STANDARD-ANTIVIRUS-TEST-FILE!$H+H*
```

Renommez ensuite le fichier créé pour en changer l'extension de « .txt » en « .com ».

8. Que se passe-t-il ? Expliquez pourquoi.

```
# Lorsque le fichier Eicar est créé avec l'extension .com,  
# l'antivirus Windows Defender le détecte immédiatement  
# comme une menace potentielle et le met en quarantaine ou le supprime.  
# Cela se produit parce que le contenu du fichier correspond à la  
# signature de test standard utilisée pour vérifier le bon fonctionnement  
# des logiciels antivirus.
```

9. Quelle est la commande PowerShell qui installe la fonctionnalité Antivirus Microsoft Defender sur un serveur Windows 2022 ? et celle que l'on peut utiliser pour vérifier que le service fonctionne ?

```
# Pour installer Microsoft Defender Antivirus sur Windows Server 2022  
Install-WindowsFeature -Name Windows-Defender-Features  
  
# Pour vérifier que le service fonctionne  
Get-Service -Name WinDefend
```

10. Est-ce que la sécurité Windows propose des fonctions pour traiter les ransomware ?

```
# Oui, Windows Security propose une fonctionnalité appelée  
# "Accès contrôlé aux dossiers" qui protège les dossiers  
# contre les modifications non autorisées, y compris celles  
# effectuées par des ransomwares.
```

## MISE À JOUR DES SYSTÈMES D'EXPLOITATION

---

Avoir des systèmes d'exploitations à jour est très important pour sécuriser un système informatique. Lorsqu'un ordinateur est à jour, c'est-à-dire que toutes les mises à jour publiées par l'éditeur, en l'occurrence ici Microsoft, sont installées, il est protégé contre les vulnérabilités connues.

A contrario, les ordinateurs où les mises à jour ne sont pas installées sont vulnérables : un logiciel malveillant peut en tirer profit pour compromettre cet ordinateur. Ceci est bien entendu valable pour les serveurs et tous les autres équipements (pare-feu, commutateurs, smartphones, etc.).

11. Quel service permet d'installer les correctifs de sécurité Windows ?

- # Le service Windows Update (wuauserv) permet d'installer
- # les correctifs de sécurité Windows.

12. D'après vous quels problèmes peuvent poser les mises à jours Windows ?

- # Les problèmes potentiels liés aux mises à jour Windows incluent :
- # - Incompatibilité avec certains logiciels ou matériels existants.
- # - Pannes ou dysfonctionnements du système après une mise à jour.
- # - Temps d'arrêt prolongé pendant l'installation des mises à jour.
- # - Problèmes de connectivité réseau ou de performances.
- # - Risques de sécurité si les mises à jour ne sont pas
- # appliquées rapidement.

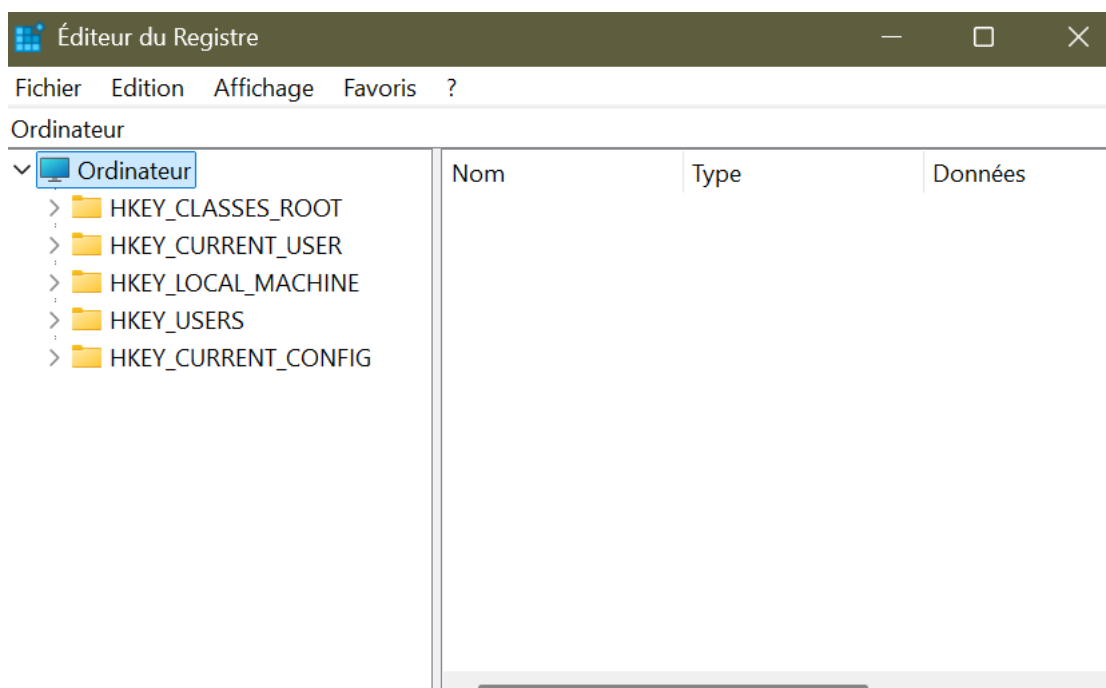
13. Quelles solutions peut-on mettre en place pour éviter les problèmes dus aux mises à jour Windows?

- # Pour éviter les problèmes liés aux mises à jour Windows,
- # on peut mettre en place les solutions suivantes :
- # - Tester les mises à jour dans un environnement de test avant de
- # les déployer en production.
- # - Planifier les mises à jour pendant les périodes de
- # faible activité.
- # - Utiliser des outils de gestion des mises à jour pour contrôler
- # le déploiement.
- # - Maintenir des sauvegardes régulières des systèmes avant
- # d'appliquer les mises à jour.
- # - Informer les utilisateurs des changements et des
- # éventuels impacts.

## SAVOIR TROUVER LE PARAMÉTRAGE DE WINDOWS DANS LE REGISTRE WINDOWS

La base de registre Windows est une base de données structurée, c'est un composant incontournable. Les administrateurs système doivent la connaître et savoir la manipuler. Elle contient les données de configuration du système d'exploitation et des autres logiciels installés désirant s'en servir. Le système et les applications y stockent de nombreuses informations.

Pour accéder à la base de registre exécutez **regedit**, l'éditeur de registre.



Les paramètres généraux de Windows Update sont dans :

`HKLM\SOFTWARE\Microsoft\WindowsUpdate\UX\Settings4`

Vous y retrouvez les paramètres que l'on peut fixer via l'interface graphique.

14. Sous Windows 2022 server : quel est le rôle qui permet de dédier des serveurs à la gestion et au stockage des mises à jours ? Vous pouvez explorer les rôles possibles de votre VM serveur Windows 2022 et le trouver facilement. Quelle commande PowerShell permet de lister les rôles du serveur ?

```
# Le rôle est "Windows Server Update Services (WSUS)".  
# La commande PowerShell pour lister les rôles du serveur est :  
Get-WindowsFeature
```

15. Vous devez vérifier les mises à jours sur votre VM Ubuntu Server, les installer si c'est nécessaire et programmer une mise à jour régulière. Comment vérifier s'il existe des mises à jour ? Comment les installer ? Comment les programmer ?

```
# Pour vérifier les mises à jour sur Ubuntu Server :  
sudo apt update
```

```
# Pour installer les mises à jour disponibles :  
sudo apt upgrade -y
```

```
# Pour programmer une mise à jour régulière, vous pouvez utiliser cron.  
# Par exemple, pour exécuter une mise à jour quotidienne à 2h du matin,  
# ajoutez la ligne suivante au crontab avec 'crontab -e' :  
0 2 * * * sudo apt update && sudo apt upgrade -y
```

## PARAMÉTRAGE DE WINDOWS

---

La stratégie de sécurité locale de Windows permet de configurer de nombreux éléments de sécurité pour un ordinateur particulier. . Quand les PC font partie d'un domaine Active Directory vous pourrez utiliser les stratégies de groupe au niveau du domaine.

16. Comment modifier les stratégies de sécurité locales d'un poste particulier ? Quel droit faut il ?

```
# Pour modifier les stratégies de sécurité locales d'un poste,  
# ouvrez l'éditeur de stratégie de sécurité locale en exécutant  
# "secpol.msc" depuis la boîte de dialogue Exécuter (Win + R).  
# Vous devez avoir des droits d'administrateur pour effectuer  
# ces modifications.
```

## EXCERCICES D'APPLICATION

---

Créez un compte **Administrateur local protégé par mot de passe** sur le poste de travail (seul compte autorisé à exécuter des tâches d'administration sur le poste). Créez un compte **utilisateur local** membre du groupe local **"Utilisateurs"**. Pour cet exercice, **l'administrateur** du poste de travail s'appellera **"Admin"**, et l'utilisateur s'appellera **"Utilisateur1"**. N'oubliez pas de les remplacer à chaque fois par des noms d'utilisateurs qui sont propres à votre environnement

```
# Créer le compte Administrateur local  
$adminUsername = "Admin"  
$adminPassword = Read-Host "Entrez le mot de passe pour  
l'administrateur" -AsSecureString  
New-LocalUser -Name $adminUsername  
-Password $adminPassword
```

```

-FullName "Administrateur Local"
-Description "Compte administrateur local"
Add-LocalGroupMember -Group "Administrators" -Member $adminUsername
Write-Host "Le compte administrateur local '$adminUsername' a été
créé avec succès."
# Créer le compte utilisateur local
$userUsername = "Utilisateur1"
$userPassword = Read-Host "Entrez le mot de passe pour
l'utilisateur" -AsSecureString
New-LocalUser -Name $userUsername
-Password $userPassword
-FullName "Utilisateur Local"
-Description "Compte utilisateur local"
Add-LocalGroupMember -Group "Users" -Member $userUsername
Write-Host "Le compte utilisateur local '$userUsername' a été
créé avec succès."

```

17. Comment créer une stratégie de sécurité locale qui bloque le port USB d'un PC physique quand un utilisateur particulier, Utilisateur1, se connecte ? Pourquoi le faire ?

```

# Pour créer une stratégie de sécurité locale qui bloque
# le port USB
# pour un utilisateur spécifique, vous pouvez utiliser l'éditeur
# de stratégie
# de sécurité locale (secpol.msc) et configurer les paramètres
# de restriction
# des périphériques amovibles.
# Cependant, cette fonctionnalité n'est pas directement disponible
# pour un utilisateur spécifique via secpol.msc. Vous devrez utiliser
# des stratégies de groupe (GPO) dans un environnement Active
# Directory pour appliquer cette restriction à un utilisateur
# spécifique.
#
# Le blocage des ports USB peut être fait pour des raisons de
# sécurité, afin d'empêcher l'introduction de logiciels
# malveillants via des périphériques
# USB ou pour protéger les données sensibles contre le vol.

```

18. Comment mettre en place une stratégie de mot de passe locale sur un poste et pourquoi ?

```

# Pour mettre en place une stratégie de mot de passe locale,
# ouvrez l'éditeur de stratégie de sécurité locale en exécutant
# "secpol.msc" depuis la boîte de dialogue Exécuter (Win + R).
# Naviguez vers "Stratégies de compte" > "Stratégie de mot de passe".
# Vous pouvez définir des paramètres tels que la
# longueur minimale du mot de passe,

```

```
# la complexité requise, et la durée de vie maximale du mot de passe.  
#  
# Mettre en place une stratégie de mot de passe est important pour  
# renforcer la sécurité des comptes utilisateurs, réduire le risque  
# d'accès non autorisé et protéger les données sensibles.
```

## 19. Comment activer le contrôle des applications (AppLocker) ? Pourquoi l'activer ?

```
# Pour activer AppLocker, ouvrez l'éditeur de stratégie de  
# sécurité locale en exécutant "secpol.msc" depuis la boîte  
# de dialogue Exécuter (Win + R).  
# Naviguez vers "Stratégies de contrôle des  
# applications" > "AppLocker".  
# Vous pouvez créer des règles pour les exécutable, les scripts,  
# les fichiers DLL, etc., afin de contrôler quelles  
# applications peuvent s'exécuter sur le système.  
#  
# Activer AppLocker est important pour renforcer la sécurité en  
# empêchant l'exécution de logiciels non autorisés ou malveillants,  
# ce qui aide à protéger le système contre les attaques et les  
# infections par des logiciels malveillants.
```

## PARAMÉTRAGE DES MISES À JOURS WINDOWS

---

Une stratégie de groupe locale (ou Local Group Policy) est un ensemble de paramètres de configuration qui s'appliquent à un ordinateur Windows de manière locale, c'est-à-dire sans nécessiter de connexion à un réseau ou à un serveur Active Directory (AD). Connectez vous avec le compte administrateur :

- Appuyez sur les touches Windows + R pour ouvrir la fenêtre Exécuter
- Tapez gpedit.msc et appuyez sur Entrée

## 20. Comment utiliser une stratégies de groupe locale pour paramétrer Windows update et Windows defender ?

```
# Pour paramétrer Windows Update via la stratégie de groupe locale,  
# ouvrez l'éditeur de stratégie de groupe locale (gpedit.msc).  
# Naviguez vers "Configuration ordinateur" >  
# "Modèles d'administration"  
# > "Composants Windows" > "Windows Update".  
# Vous pouvez configurer des paramètres tels que la planification  
# des mises à jour automatiques, les notifications, et plus encore.
```

```
# Pour paramétrer Windows Defender, naviguez vers
# "Configuration ordinateur" > "Modèles d'administration"
# > "Composants Windows" > "Microsoft Defender Antivirus".
# Vous pouvez configurer des paramètres tels que la protection en
# temps réel, les exclusions, et d'autres options de sécurité.
```

## LES SYSTÈMES LINUX NE SONT PAS À L'ABRI DES RANSOMWARES

---

Les attaques de ransomware sur les réseaux Linux sont menées par des moyens plus subversifs que les attaques sur un système Windows. Les acteurs malveillants recherchent les vulnérabilités des composants des systèmes Linux.

Les machines virtuelles, les conteneurs et les services de stockage en nuage fonctionnant sous Linux sont souvent pris pour cible, surtout s'ils ne disposent pas de contrôles d'accès appropriés. De nombreux sites web et services en ligne fonctionnent sous Linux. Les ransomwares peuvent se propager par le biais de plateformes CMS compromises, de plugins obsolètes ou d'identifiants d'administration faibles.

Les périphériques NAS fonctionnent souvent avec un système d'exploitation basé sur Linux et stockent des sauvegardes critiques, ce qui en fait des cibles précieuses. Au-delà des serveurs traditionnels et de l'infrastructure en nuage, un nombre croissant de dispositifs IoT basés sur Linux sont également des cibles potentielles. Si tout système Linux vulnérable peut être la cible d'un ransomware, certains types d'appareils présentent un risque plus élevé en raison de leur fonction et de leurs faiblesses communes en matière de sécurité : Les entreprises qui utilisent des serveurs basés sur Linux pour les bases de données, les applications et le stockage sont des cibles de choix. Les attaquants exploitent les faiblesses de SSH, les logiciels non corrigés et les mauvaises configurations.

Pour les prévenir, il est important de savoir maintenir les logiciels à jour, de savoir restreindre les privilèges, de savoir mettre une politique de mots de passe forts et de savoir restreindre la sécurité SSH.

## GESTION DES UTILISATEUR AVEC UBUNTU SERVER

---

La gestion des utilisateurs est une partie cruciale de la sécurisation du système. Une gestion inefficace des utilisateurs et de leurs droits conduit souvent de nombreux systèmes à être corrompus. Il est donc fondamental de comprendre comment vous pouvez protéger votre serveur aux travers de techniques simples de gestion des comptes utilisateurs.

## 21. Comment gérer les utilisateurs et les groupes ?

```
# Pour gérer les utilisateurs sur Ubuntu Server, vous pouvez utiliser
# les commandes suivantes :
#
# Ajouter un nouvel utilisateur :
sudo adduser nom_utilisateur
#
# Supprimer un utilisateur :
sudo deluser nom_utilisateur
#
# Ajouter un utilisateur à un groupe :
sudo usermod -aG nom_groupe nom_utilisateur
#
# Supprimer un utilisateur d'un groupe :
sudo gpasswd -d nom_utilisateur nom_groupe
#
# Lister les utilisateurs :
cut -d: -f1 /etc/passwd
#
# Lister les groupes :
cut -d: -f1 /etc/group
```

## 22. Comment gérer la politique des mots de passe sur un serveur Ubuntu?

```
# Pour gérer la politique des mots de passe sur Ubuntu Server,
# vous pouvez modifier le fichier /etc/pam.d/common-password
# et utiliser le module pam_pwquality.so pour définir des règles
# de complexité des mots de passe.
#
# Par exemple, pour exiger une longueur minimale de mot de passe
# et des caractères spéciaux, vous pouvez ajouter ou modifier
# la ligne suivante dans /etc/pam.d/common-password :
password requisite pam_pwquality.so retry=3 minlen=12 ucredit=-1
lcredit=-1 dcredit=-1 ocredit=-1
#
# Après avoir modifié le fichier, enregistrez les changements
# et les nouvelles politiques seront appliquées lors de la
# création ou du changement de mot de passe.
```

23. Comment restreindre l'accès en SSH aux seuls comptes utilisateurs qui devrait l'avoir ?

```
# Pour restreindre l'accès SSH aux seuls comptes utilisateurs
# autorisés, vous pouvez modifier le fichier de configuration
# SSH situé à /etc/ssh/sshd_config.
#
# Ajoutez la ligne suivante pour spécifier les utilisateurs
# autorisés à se connecter via SSH :
AllowUsers utilisateur1 utilisateur2
#
# Vous pouvez également utiliser AllowGroups pour autoriser
# uniquement les membres d'un groupe spécifique :
AllowGroups groupe_ssh
#
# Après avoir modifié le fichier, enregistrez les changements
# et redémarrez le service SSH pour appliquer les modifications :
sudo systemctl restart sshd
```

24. Comment maintenir son serveur et ses logiciels à jour ?

```
# Pour maintenir votre serveur Ubuntu et ses logiciels à jour,
# vous pouvez utiliser les commandes suivantes :
#
# Mettre à jour la liste des paquets disponibles :
sudo apt update
#
# Mettre à niveau les paquets installés vers leurs
# dernières versions :
sudo apt upgrade
#
# Pour une mise à niveau complète, incluant les
# changements de dépendances :
sudo apt full-upgrade
#
# Nettoyer les paquets obsolètes :
sudo apt autoremove
```

# ANALYSE ET RÉOLUTION : LA RANÇON DU CYBERESPACE

---

## Rappel des commandes PowerShell et Bash utilisées

### Windows — PowerShell

```
# Verifier l'etat du pare-feu
Get-NetFirewallProfile

# Activer le pare-feu sur tous les profils
Set-NetFirewallProfile -Profile Domain,Public,Private -Enabled True

# Lister les mises a jour disponibles
Get-WindowsUpdate

# Installer toutes les mises a jour
Install-WindowsUpdate -AcceptAll -AutoReboot

# Desactiver les services inutiles
Set-Service -Name "Spooler" -StartupType Disabled

# Verifier les comptes locaux
Get-LocalUser

# Activer l'audit avance
auditpol /set /category:* /success:enable /failure:enable

# Lister les ports ouverts
Get-NetTCPConnection

# Activer la protection Windows Defender
Set-MpPreference -DisableRealtimeMonitoring $false
```

### Ubuntu — Bash

```
# Mise a jour du syst me
sudo apt update && sudo apt upgrade -y

# Verifier les services actifs
systemctl list-units --type=service

# Desactiver un service inutile
sudo systemctl disable bluetooth.service --now
```

```
# Configurer UFW
sudo ufw enable
sudo ufw default deny incoming
sudo ufw default allow outgoing

# Lister les ports ouverts
sudo ss -tulnp

# Verifier les comptes et groupes
cat /etc/passwd
cat /etc/group

# Installer les outils de securite essentiels
sudo apt install fail2ban unattended-upgrades -y

# Activer les mises a jour automatiques
sudo dpkg-reconfigure unattended-upgrades

# Verifier l'integrite du syst me
sudo debsums -s
```

Réalisation d'une brochure de sensibilisation aux risques liés aux ransomwares à destination des utilisateurs finaux.

## COMMENT S'EN PROTÉGER

- Ne pas partager de données personnelles
  - Limitez la diffusion d'informations sensibles pour éviter les risques d'exploitation.
- Maintenir son matériel à jour
  - Installez les mises à jour de sécurité régulièrement pour corriger les failles.
- Utiliser un mot de passe sécurisé
  - Un bon mot de passe doit inclure au moins :
    - Une majuscule
    - Un caractère spécial
    - Un chiffre
    - 12 caractères
  - ne pas réutiliser un mot de passe
- Vérifier les sites visités
  - Avant de cliquer, vérifiez que l'adresse est correcte (ex. : "google.fr", pas "gooqle.fr") et préférez les sites en "HTTPS" pour plus de sécurité.

## DONNÉES OUTILS

Keypass: application pour générer et stocker des mots de passe

Apprenez en plus sur : [secnumacademie.gouv.fr](http://secnumacademie.gouv.fr)



## TOUT LE MONDE PEUT ÊTRE VICTIME DES CYBERATTQUES

## LA VULNÉRABILITÉ CROISSANTE

Malgré les différentes innovations technologiques, tous les dispositifs connectés restent malheureusement vulnérables. Chaque appareil connecté représente un potentiel point d'accès pour un cyberdélinquant.



De nos jours, presque tout le monde possède un ou plusieurs appareils connectés, tels que des téléphones ou des ordinateurs portables. Cependant, le transfert de données ne se limite pas au Wi-Fi : en effet, les appareils peuvent aussi se connecter via Bluetooth. Cela élargit notre accès à de nombreux dispositifs connectés, comme les montres intelligentes ou les réfrigérateurs connectés, augmentant ainsi la taille de notre écosystème numérique tout en nous rendant plus vulnérables aux attaques.

## TYPES DE CYBERATTQUES

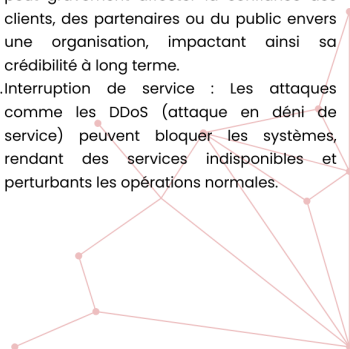
Les attaques les plus utilisées par les cybercriminels sont le phishing et les virus, chacun ayant des objectifs différents.

- Le phishing : il s'agit d'une méthode dans laquelle le cyberdélinquant se fait passer pour une organisation de confiance, comme Google ou un site bancaire, pour vous inciter à entrer vos identifiants et ainsi les voler.
- Les virus : c'est des logiciels malveillants ayant divers objectifs, tels que :
  - L'espionnage de vos données : ces virus sont appelés "spywares" et collectent des informations à votre insu.
  - L'endommagement de vos données : ces malwares, parmi les plus connus, visent à altérer ou à détruire les fichiers.
  - Le cryptage de vos données : ici, le virus chiffre vos informations pour ensuite exiger une rançon en échange de la clé de déchiffrement. Ces attaques sont connues sous le nom de "ransomwares".

## CONSÉQUENCES

Les conséquences d'une cyberattaque peuvent être graves et multiples :

1. Perte de données : Les informations personnelles ou professionnelles peuvent être volées, endommagées ou supprimées, ce qui entraîne une perte de valeur pour les individus et les entreprises.
2. Impact financier : Entre les coûts de récupération, les pertes d'activité et les rançons potentielles (dans le cas de ransomwares), les cyberattaques peuvent coûter très cher.
3. Atteinte à la réputation : Une cyberattaque peut gravement affecter la confiance des clients, des partenaires ou du public envers une organisation, impactant ainsi sa crédibilité à long terme.
4. Interruption de service : Les attaques comme les DDoS (attaque en déni de service) peuvent bloquer les systèmes, rendant des services indisponibles et perturbant les opérations normales.



## CONCLUSION

---

Ce document a permis de revoir les notions de base de PowerShell, la gestion des utilisateurs locaux sur un poste Windows, la sécurité des postes Windows avec Windows Security, la protection antivirus, la mise à jour des systèmes d'exploitation Windows et Ubuntu Server, la navigation et la modification du registre Windows, le paramétrage de Windows via les stratégies de groupe locales, ainsi que la gestion des utilisateurs et la sécurité sur Ubuntu Server.

## CAPITALISATION

---

Ce document a permis de revoir les notions suivantes :

- Les bases de PowerShell et la création de scripts simples.
- La gestion des utilisateurs locaux sur un poste Windows.
- La sécurité des postes Windows avec Windows Security.
- La protection antivirus et l'utilisation du fichier de test Eicar.
- La mise à jour des systèmes d'exploitation Windows et Ubuntu Server.
- La navigation et la modification du registre Windows.
- Le paramétrage de Windows via les stratégies de groupe locales.
- La gestion des utilisateurs et la sécurité sur Ubuntu Server.

## RESSOURCES

---

- Corbeille d'Exercice.
- Documentation officielle de PowerShell : <https://docs.microsoft.com/fr-fr/powershell/>
- Documentation officielle d'Ubuntu Server : <https://ubuntu.com/server/docs>
- Tutoriels sur la gestion des utilisateurs et la sécurité sous Linux : <https://linuxconfig.org/>
- Tutoriels sur la gestion des utilisateurs et la sécurité sous Windows :